

Relatório: Mitigação de Phishing

Medidas Técnicas

1. Filtro de e-mail na borda. Bloqueia domínios suspeitos, anexos executáveis, links encurtados e spoofing de display name, e manda o resto para quarentena com revisão manual.
2. SPF, DKIM e DMARC com política de rejeição. Sem eles, qualquer um envia e-mail em nome da empresa.
3. MFA obrigatório em e-mail e em sistemas financeiros. Uma credencial vazada por phishing deixa de valer quando existe o segundo fator.
4. Isolamento do navegador para abrir anexos e links recebidos. O arquivo roda numa sandbox, o malware não alcança a máquina do usuário.
5. EDR nos endpoints e alerta de login fora de padrão. Conta comprometida gera acesso de outro país ou horário estranho, e o alerta dispara antes do estrago maior.

Medidas educacionais e organizacionais

1. Simulados mensais de phishing com retorno individual imediato para quem clicou. O objetivo é registrar o erro, nunca punir.
2. Treinamento em ciclos curtos: quinze minutos a cada quinzena, em vez de um curso anual que ninguém lembra na semana seguinte.
3. Canal único de reporte: um botão no próprio e-mail que encaminha a suspeita para a equipe de segurança. Resposta rápida e nenhuma advertência para quem reporta.
4. Comunicado de ameaças reais. Quando uma tentativa chega de verdade, descrever o que ela fazia e por que quase funcionou. O caso concreto ensina mais que a aula genérica.
5. Um multiplicador de segurança por departamento, com treinamento reforçado, para revisar pedidos fora do padrão. O tema entra no onboarding e nas metas.